

REF	DATE	TYPE	AUTHOR	STATUS
W4-R-2026-003	APR 2026	TECHNICAL NOTE	ENOCH KAN	PUBLISHED

The Inference Stack Is an Attack Surface

What model files, serving frameworks, and the ML supply chain teach us about the layer of AI risk nobody's prompt-engineering away.

ABSTRACT

Most AI security attention goes to model behaviour: jailbreaks, prompt injection, harmful outputs. Meanwhile, the software that loads, serves, and orchestrates models is ordinary infrastructure with extraordinary privileges — and it has been failing in ordinary ways. This note examines three layers of the inference stack as attack surface: model artifacts that execute code on load, public model hubs as a supply chain, and serving frameworks exposed as network services. Each layer has produced real-world compromises. The conclusion is unglamorous and important: AI security inherits everything application security already knows, and teams that treat model artifacts as data rather than code are running executables from strangers.

1. Model files are programs

The most consequential fact in ML supply-chain security is also the least intuitive to newcomers: many common model serialisation formats can execute arbitrary code when the file is loaded. Python's pickle format — long the default beneath PyTorch checkpoints and countless libraries — deserialises by executing instructions embedded in the file. Loading a malicious checkpoint is not like opening a malformed image; it is like running an installer. Security researchers have repeatedly demonstrated, and found in the wild, model files on public hubs that open reverse shells or exfiltrate credentials at load time.

The ecosystem's answer is safer-by-construction formats, most notably safetensors, which stores raw tensor data and cannot smuggle executable payloads. Adoption is broad but not universal, and legacy checkpoints, converter scripts, and "just this once" downloads keep the pickle path alive in most organisations.

Recommendations

- Treat model artifacts as untrusted executables, not data files. Apply the same policy you would to running a downloaded binary.
- Standardise on safetensors (or equivalent non-executable formats) for storage and interchange; convert legacy checkpoints in a sandbox.

- Scan artifacts before load with model-file scanners, and load anything unscanned in an isolated, non-privileged environment.

2. Model hubs are a supply chain

Public hubs have done for models what package registries did for code — including recreating the same attack patterns. Researchers have found hundreds of malicious models uploaded to popular hubs, using payloaded serialisation, typosquatted names, and README social engineering. And the classic registry attacks apply directly: in December 2022, the PyTorch nightly build was compromised via dependency confusion when a malicious torchtriton package on PyPI shadowed the internal dependency, exfiltrating data from machines that installed it. Nothing about that attack was AI-specific; everything about its blast radius was.

The lesson from a decade of software supply-chain security transfers wholesale: pin versions and hashes, verify publishers, mirror what you depend on, and maintain an inventory. If your organisation produces a software bill of materials, your models, datasets, and fine-tunes belong in it. An "AI BOM" is not a new discipline — it is the old discipline, applied to artifacts your tooling currently ignores.

3. Serving frameworks are network services

Inference servers, orchestration frameworks, and experiment trackers are web services, and they fail like web services: unauthenticated APIs, server-side request forgery, path traversal, and remote code execution have all been disclosed across the popular open-source ML stack in recent years. Two structural factors make the consequences worse than the average web app.

- **Privilege concentration.** The serving layer holds the crown jewels by design: model weights (expensive IP), GPU compute (monetisable), and often credentials to data stores and vector databases.
- **Deploy-fast culture.** ML infrastructure is frequently stood up by research or data teams outside standard hardening pipelines, exposed to the internet "temporarily," and forgotten.

The ShadowRay campaign made this concrete: attackers exploited an unauthenticated job-submission API in the Ray framework (CVE-2023-48022, disputed by the vendor as intended behaviour, which is precisely the point) to run cryptominers and steal credentials across thousands of exposed clusters. The vulnerability class was not novel. The deployment pattern was the vulnerability.

Recommendations

- Inventory every ML service with a listening port; assume research deployments are internet-exposed until proven otherwise.
- Put authentication, TLS, and network segmentation in front of inference and orchestration APIs — frameworks' insecure-by-default configurations are documented, not hypothetical.
- Patch the ML stack on the same SLA as any internet-facing software, and subscribe to advisories for every framework you run.
- Separate the serving plane from training data and secrets; a compromised inference node should not read your data lake.

4. The unglamorous conclusion

None of the failures above required adversarial cleverness against a model. They required a downloaded file, an open port, and a missing control — the same ingredients as every breach retrospective of the last twenty years. Teams securing AI systems should of course keep working on model behaviour. But behavioural security sits on top of infrastructure security, and an attacker with code execution on your inference host does not need to jailbreak anything.

Our position: the fastest risk reduction available to most AI teams in 2026 is not a better guardrail model. It is applying the boring, proven controls of application and supply-chain security to the stack their models already run on.

References

PyTorch Team (2022). Compromised PyTorch-nightly dependency chain (torchtriton dependency-confusion incident), December 2022 disclosure.

Oligo Security (2024). ShadowRay: attack campaign against exposed Ray clusters (CVE-2023-48022).

JFrog Security Research (2024). Analyses of malicious machine-learning models discovered on public model hubs.

Hugging Face. Safetensors: a safe format for storing and distributing tensors.

OWASP Foundation. OWASP Top 10 for LLM Applications — supply-chain and insecure-plugin categories.

// © 2026 W4 Advisory. Published under CC BY 4.0. Feedback: hello@w4advisory.com